Introducción



Los sistemas de gestión de seguridad de la información o SGSI es un término que se utiliza en la Norma Internacional ISO 27001 para referirse al conjunto de políticas, normas y controles que se aplican en una organización para garantizar el cumplimiento de los pilares de la seguridad de la información como lo son la integridad, la disponibilidad y la confidencialidad.

Es el estándar internacional para la seguridad de la información que establece la especificación para un sistema de gestión de seguridad de la información (SGSI).

El enfoque de mejores prácticas del estándar del sistema de gestión de seguridad de la información ayuda a las organizaciones a gestionar su seguridad de la información dirigiéndose a las personas y los procesos, así como a la tecnología.

La certificación acreditada de forma independiente de la norma ISO 27001 es reconocida en todo el mundo como una indicación de que su SGSI está alineado con las mejores prácticas de seguridad de la información.

1
ISO IEC 27001

> Es el estándar internacional que define los requerimientos necesarios para establecer, implementar, mantener y actualizar los sistemas de gestión de seguridad de la información.

Para la implantación de un sistema de gestión de la seguridad de la información, se requiere del desarrollo de actividades que marquen un orden lógico para llevar organizado todo el proceso. El modelo PDCA (Plan, do, check, act), en su equivalencia en español es planificar, hacer, verificar y actuar (PHVA), es una estrategia de mejora continua de calidad en cuatro pasos.

Este modelo es muy utilizado para la implantación de sistemas de gestión, como los sistemas de gestión de la calidad que muchas empresas de hoy lo implantan para la calidad administrativa y de servicios con el objetivo de perfeccionarlos y continuar en un proceso de mejora continua.

1.1 Fases del ciclo PHVA

1.1.1 Planear

En esta etapa se enmarca todo el proceso de análisis de la situación en que actualmente se encuentra la empresa respecto a los mecanismos de seguridad implementados y la normativa ISO/IEC 27001:2017 la cual se pretende implantar para evaluación y certificación. Las etapas relevantes de esta fase son:

Establecer el compromiso con los directivos de la empresa para el inicio, proceso y ejecución.

Definir el alcance del SGSI.

Definir las políticas de seguridad.

Selección y aplicación de una metodología de análisis y evaluación de riesgos.

Fase de análisis de información de la organización, en esta fase se comprueba cuáles son los sistemas informáticos de hardware y los sistemas de información que actualmente utiliza la empresa para el cumplimiento de su misión u objeto social.

Fase de evaluación del riesgo; En esta fase se evalúa los riesgos, se tratan y se seleccionan los controles a implementar.

1.1.2 Hacer

En esta fase se hace la implementación de los controles que se definen de acuerdo al plan de tratamiento de riesgos definidos una vez construida la matriz de riesgos en la etapa anterior. Las actividades más relevantes de esta etapa son:

Definir el plan de tratamiento de riesgos.

Implantar el plan de tratamiento de riesgos.

Selección e implementación de controles (Anexo A ISO 27002:2013).

Formación y concientización (a toda la organización).

1.1.3 Verificar

Esta es una fase donde se hace una revisión y evaluación del desempeño de los controles implementados buscan medir la eficacia y eficiencia de los controles seleccionados e implementados. Las etapas de esta fase son:

Revisión del Sistema de Gestión de Gestión de seguridad.

Medir la eficacia de los controles seleccionados e implementados.

Se miden y revisan si existen riesgos residuales.

Realización de auditorías internas al Sistema de gestión de seguridad de la información.

Registro de todas las acciones y eventos generados durante las pruebas y validaciones.

1.1.4 Actuar

Como se mencionaba al principio el ciclo se requiere una mejora continua por esta razón en esta fase se busca actualizar o realizar los cambios a los controles identificados en la fase anterior que no están cumpliendo con la eficacia y eficiencia requerida. Las etapas de esta fase son:

Implantar mejoras al SGSI.

Definición y aplicaciones de acciones preventivas y correctivas.

Verificación de la eficiencia de las acciones ejecutadas.

2

Plan de gestión de un SGSI

La ISO 27001, expresa que un **Sistema de Gestión de la Seguridad de la información**, es un sistema de gestión que comprende la política, estructura organizativa, los procedimientos, los procesos y los recursos necesarios para implantar la gestión de la seguridad de la información. Este sistema es la herramienta que dispone la dirección de las organizaciones para llevar a cabo las políticas y objetivos de seguridad (integridad, confidencialidad y disponibilidad, asignación de responsabilidad, autenticación, etc.). Este sistema proporciona mecanismos para la salvaguarda de los activos de información y de los sistemas que los procesan, en concordancia con las políticas de seguridad y planes estratégicos de la organización.



Plan de gestión de un SGSI

3

Definir el alcance del SGSI

Definir el alcance para la implementación del sistema en una organización es uno de los primeros aspectos que se debe considerar. Teniendo en cuenta que existen organizaciones que difieren en tamaño por el número de empleados, volumen de información manejada, número de clientes, volúmenes de activos físicos y lógicos, número de sedes u oficinas, entre otros elementos, se hace necesario determinar qué áreas o dependencias de la organización se desea implantar el SGSI como primera medida y cuales posteriormente. Las primeras áreas que se deben considerar son aquellas que por sus funciones y responsabilidades ayudan en primera instancia a dar cumplimiento a la misión institucional.



Alcance del SGSI

4

Política de seguridad

La política de seguridad es el primer documento que se debe contemplar, por cuanto es donde se especifica toda la normativa interna de la institución con el objetivo de que los funcionarios conozcan y cumplan sobre el sistema de gestión de la seguridad informática (SGSI) implantado, con este documento, también se refleja el compromiso planteado por la dirección. Así mismo contempla todos los aspectos orientados al acceso a la información, utilización de los activos físicos y lógicos de la organización y el comportamiento que debe hacer en caso de que ocurra un incidente de seguridad.



Política de seguridad

5

Diseño del SGSI



Diseño del SGSI

El análisis de requisitos consiste en estudiar los requisitos de seguridad de la información para el proceso SGSI bajo la normativa ISO/IEC 27001 definidos. Los requisitos son aquellas exigencias que la normativa determina para el SGSI y son susceptibles de análisis, el diseño del SGSI, abarca todos los aspectos de planeación y trazado de la ruta a seguir para la implantación del SGSI en la organización.

6

Auditoria al SGSI

Una auditoría interna es el proceso mediante el cual la organización evalúa el cumplimiento de la implantación del Sistema de Gestión de la Seguridad de la información en una empresa bajo la normativa ISO/IEC 27001.

Los aspectos más importantes de una auditoría interna son:

Las auditorías internas deben estar bien planificadas (plan auditor) y aprobadas por la dirección.

El equipo auditor deben ser profesionales idóneos con experiencia y diferentes a los encargados de la implantación del SGSI en la organización.

Se debe estipular un coordinador del equipo auditor.

Las auditorías se deben orientar hacia la correcta implantación de los 14 dominios, 35 objetivos de control y 114 controles de seguridad implementados.

Toda la organización debe conocer el alcance y la agenda estipulada para la auditoría interna.

Los informes y resultados deberán ser conocidos por todo el personal de la organización involucrado dentro del alcance del SGSI.

De acuerdo al informe y/o resultados presentados en la auditoría interna, la organización debe estipular los planes para mejorar la eficacia del SGSI y realizar el procedimiento documentado de las acciones correctivas y preventivas.

7

Consideraciones para la implementación de un SGSI (Norma ISO 27001)

7.1 Preguntas orientadoras de la necesidad del SGSI - ¿Cuándo y porqué implantar un SGSI en una organización?

Implantar un SGSI en una empresa no es precisamente cuando se le haya presentado un incidente de seguridad sobre su información, sino, cuando ésta desea tener un crecimiento y posicionamiento ante un mercado exigente y global teniendo en cuenta que, para ello, requerirá del uso de la Tecnología de la información y las comunicaciones para lograrlo. En tal sentido, un SGSI, va permitir de forma organizada y sistémica, mantener la seguridad de la información que maneja la empresa con un alto grado de confiabilidad, integridad y disponibilidad. Así como el estar preparados para afrontar un incidente de seguridad que rompa las barreras (medidas de seguridad) de seguridad implantadas y estar en la capacidad de poner en funcionamiento rápidamente la empresa o que es lo mismo evitar que sus clientes lo perciban o lo vean.

7.2 ¿Qué aspectos se deben considerar al implantar un SGSI?

La seguridad de la información es un compromiso de todos en una organización. Aunque esto sea claro para muchos empleados de una empresa, para otras no lo es, es por ello que uno de los aspectos relevantes a la hora de implementar un SGSI, es concientizar a las directivas y demás empleados, la importancia y responsabilidad de proteger la información como el activo más preciado que posee que la pérdida de ella podría causar el declive parcial o total de la empresa con una afectación económica, de identidad, de marca y por ende disminución de empleados.

7.3 ¿Cuánto tiempo se requiere para implantar un SGSI?

Dado que existen organizaciones que tienen por lo menos implementada algunas medidas de seguridad sobre sus activos y éstas a la vez cumplen con la normativa ISO/IEC 27001, la implantación del SGSI llevaría alrededor de 6 meses. Pero si la empresa posee medianamente o por lo menos unas técnicas seguras de sus activos, además de la concientización de las directivas, esta podría tardar alrededor de un año.

7.4 ¿Cuánto puede costar la implantación de un SGSI?

El costo de la implantación de un SGSI, depende de múltiples variables. Una de las variables es cuando la empresa la implementa, pero a través de la contratación de terceros o entes externos que realizan todo el proceso. Otra variable es que dentro de la empresa existan empleados que poseen el conocimiento o en su defecto la organización los capacite para que posteriormente realicen la implantación. También se podría incluir como variable las herramientas que se utilicen para la implementación ya que existen actualmente múltiples sistemas de información y/o aplicativos que ayudan a desarrollar todo el proceso de manera más ágil. Por último, se podría considerar, que el costo de la implantación de un SGSI, depende de la magnitud o tamaño de la empresa ya que entre más grande sea, pues los requerimientos serán mayores o simplemente tendría que hacer la implantación por áreas, factores, dependencias o departamentos según sea la estructura organizacional de la empresa.